

Nos vamos a centrar en cómo identificar las tecnologías y versiones de servicios web.

En esta clase os voy a mostrar con qué entorno de laboratorio vamos a estar trabajando y vamos a aprender dos herramientas principalmente WhatWeb y Wappalyzer.

WhatWeb y Wappalyzer son herramientas esenciales para la identificación de servicios y tecnologías web, una etapa clave en la fase de recopilación de información de una auditoría de seguridad. Aunque tienen un objetivo similar, operan de manera diferente.

Lab environment

Como os comentaba, el laboratorio va a constar de una máquina Kali cuya IP es la 10.0.1.5 y la máquina Metasploitable 3, cuya dirección IP es la 10.0.1.9.

Y vamos a montar usando Docker la tienda online juice-shop, que se trata de una tienda online vulnerable creada por la OWASP y que está presente en github en formato repositorio.

WhatWeb

WhatWeb

- WhatWeb recognises **web technologies** including:
 - Content management systems (CMS)
 - Blogging platforms
 - Statistic/analytics packages
 - JavaScript libraries
 - Web servers
 - Embedded devices



WhatWeb es una herramienta gratuita y de código abierto que se utiliza para identificar las tecnologías web que se utilizan en un sitio o aplicación.

Se trata de una herramienta muy popular y todoterreno ya que la usan tanto profesionales de la seguridad, como desarrolladores, como administradores de sistemas.

Las tecnologías y servicios que detecta esta herramienta van desde servidores web, lenguajes, Frameworks, bibliotecas de JavaScript, sistemas de gestión de contenidos como WordPress, plataformas de comercio electrónico e incluso plataformas de blogging como puede ser Blogger.

WhatWeb es un escáner de sitios web de código abierto que reconoce tecnologías web, incluyendo sistemas de gestión de contenido (CMS), plataformas de blogs, servidores web, sistemas de análisis, librerías JavaScript y más. Utiliza más de 1.200 *plugins* para identificar tecnologías.

¿Cómo funciona WhatWeb?

WhatWeb funciona de manera **activa**, enviando peticiones HTTP al target y analizando su respuesta. Los *plugins* de WhatWeb buscan patrones en el código HTML, cabeceras HTTP, *cookies* y otros elementos para hacer una "huella digital" de las tecnologías que se están utilizando.

Parámetros y Ejemplos de Uso

A partir de la imagen proporcionada, aquí están los parámetros más importantes:

- **whatweb [opciones] <URLS>**: Es la sintaxis básica. **<URLS>** puede ser una URL, un nombre de host, una dirección IP o un rango de IP en formato CIDR.

--input-file=FILE o **-i**: Permite escanear una lista de objetivos almacenada en un archivo. Es ideal para automatizar el escaneo de múltiples sitios.

Bash

```
whatweb -i lista_sitios.txt
```

-
- **--aggression=NIVEL** o **-a**: Establece el nivel de agresividad del escaneo, lo que influye en la cantidad de peticiones que se envían. Un nivel de agresión más alto aumenta la precisión, pero también el riesgo de ser detectado.

- **1 (Stealthy/Sigiloso)**: Envía solo una petición HTTP por objetivo. Es rápido y discreto.
- **3 (Aggressive/Agresivo)**: Realiza peticiones adicionales cuando un *plugin* coincide con un patrón, lo que mejora la detección de tecnologías ocultas.

--list-plugins ○ **-l**: Muestra una lista de todos los *plugins* de detección que WhatWeb utiliza.

whatweb -l | grep wordpress # Busca solo los plugins relacionados con WordPress

- **--info-plugins** ○ **-I=[BUSQUEDA]**: Lista los *plugins* con información detallada y permite buscar por palabra clave.
- **--verbose** ○ **-v**: Proporciona una salida más detallada que incluye descripciones de los *plugins* que coinciden.

Como os comentaba, WhatWeb es open source y podemos ver que en su GitHub ya alberga más de 5.000 estrellas y que ha sido desarrollada usando Ruby.

El funcionamiento de esta aplicación se basa en enviar solicitudes HTTP a un sitio web indicado y analizando la respuesta consigue mediante una base de datos de firmas, identificar las tecnologías web que se utilizan en el sitio o aplicación.

Por otro lado, WhatWeb tiene una gran cantidad de plugins, más de 1700, que le permiten identificar una amplia gama de tecnología web.

WhatWeb

- Over 1700 plugins
- Multiple log / output format
- Proxy support (TOR)

```
(kali@kali)-[~]
$ whatweb 127.0.0.1
http://127.0.0.1 [200 OK] Apache[2.4.58], Country[RESERVED][ZZ], HTTPServer[Debian Linux]
[Apache/2.4.58 (Debian)], IP[127.0.0.1], Title[Apache2 Debian Default Page: It works]
```

Estos plugins se actualizan de forma constante para añadir nuevas tecnologías y mejorar la precisión de la identificación.

Además, soporta múltiples formatos de salida, es decir, WhatWeb puede generar resultados en una variedad de formatos como por ejemplo texto, HTML, JSON o XML.

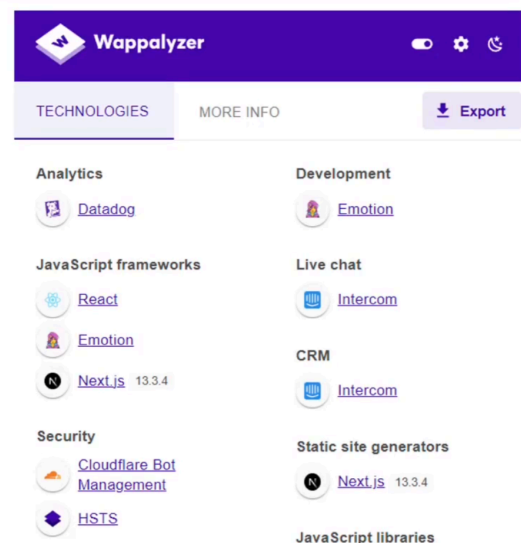
Esto nos permite elegir el formato que mejor se adapte a nosotros en cada momento. Tan solo debemos indicar el parámetro -o y el formato elegido.

Otra característica que para mí lo hace único es el soporte de proxy Tor, es decir, WhatWeb puede utilizarse a través de un proxy como Tor para ocultar nuestra dirección IP y proteger nuestra privacidad.

Wappalyzer

Wappalyzer

- Wappalyzer is a browser extension that identifies the technology used to build a website
- It runs automatically when visiting a website and quickly displays the results on the extension popup



Vamos a continuar hablando ahora de Wappalyzer.

Wappalyzer es una herramienta que nos permite, al igual que WhatWeb, identificar las tecnologías que utiliza una página web.

En este caso, a diferencia de WhatWeb, Wappalyzer funciona como una extensión para navegadores web, está soportada en Google Chrome, Firefox, Edge, Safari.

Al contrario de WhatWeb, esta herramienta es privada. Fue en un momento en el pasado de código abierto, pero luego su desarrollo se hizo privado y el último commit público data del 2008. ¿Por qué se hizo privada? No hay una única razón. Algunos hablan de que el mantenimiento era muy costoso y otros de rentabilidad, ya que actualmente ofrece pagos por uso de sus APIs.

Wappalyzer es una herramienta de identificación de tecnologías web que, a diferencia de WhatWeb, funciona de manera **pasiva**. Su forma más conocida es como una **extensión de navegador**, pero también cuenta con una versión de línea de comandos.

Uso de Wappalyzer (Extensión y CLI)

- **Extensión de Navegador:** Esta es su forma más popular y fácil de usar. Simplemente se instala en navegadores como Chrome o Firefox. Al visitar un sitio web, un icono de Wappalyzer en la barra de direcciones se ilumina y, al hacer clic, muestra una lista de todas las tecnologías detectadas. Es ideal para un reconocimiento rápido y visual.
- **Herramienta de Línea de Comandos (CLI):** Wappalyzer también tiene un *wrapper* de línea de comandos, que es útil para la automatización y la integración en *scripts*. Se instala a través de Node.js.
 - **Instalación:** `npm install -g wappalyzer`

Ejemplo de uso básico:

`wappalyzer https://example.com`

- La salida es un informe detallado en formato JSON que puede ser procesado por otros programas.

Comparación y Casos de Uso

Característica	WhatWeb	Wappalyzer
Modo de Operación	Activo (envía peticiones)	Pasivo (analiza el tráfico existente)
Mejor para	Escaneo de rangos de IP, auditorías automatizadas, análisis detallado desde la terminal.	Reconocimiento rápido y visual, uso diario, escaneo discreto a nivel de navegador.

Detección	A menudo detecta tecnologías más oscuras o de bajo nivel.	Sobresale en la detección de <i>frameworks</i> y librerías populares.
------------------	---	---

Exportar a Hojas de cálculo

En una auditoría de seguridad, se recomienda **utilizar ambas herramientas** de forma complementaria. **Wappalyzer** para obtener una visión rápida y pasiva de las tecnologías del *front-end*, y **WhatWeb** para un análisis activo y más profundo, especialmente cuando se escanean múltiples objetivos desde la terminal.

¿Qué información nos ofrece Wappalyzer?

Pues más o menos como whatweb o incluso un poquito más.

Por ejemplo Wapalyzer nos habla de herramientas de analítica como Google Analytics o Matomo. Por otro lado también nos muestra información de herramientas de marketing como Google Ads o Facebook Pixel.

¿Cómo funciona Wappalyzer?

Podemos decir que funciona de una forma similar a WhatWeb.

Wappalyzer no envía paquetes adicionales al servidor. Simplemente **analiza la página web que ya has cargado en tu navegador**, examinando elementos como:

- **Cabeceras HTTP:** Busca patrones en el **Server** o **X-Powered-By**.
- **Código fuente:** Analiza las etiquetas **meta** y el código JavaScript.
- **Archivos:** Comprueba la estructura de URL o nombres de archivos comunes (por ejemplo, **wp-content/** para WordPress).

Lo que hace es analizar el código fuente y los encabezados HTTP de una página web. Para ello utiliza una base de datos de patrones para identificar qué tecnologías se están utilizando en cada momento.

Además cabe destacar de que Wappalyzer al ser una extensión, se vale de las peticiones enviadas por nuestro navegador y por ende no necesita enviar más, por lo que podríamos decir que es una herramienta pasiva entre comillas.

Es por ello que se dice que Wappalyzer se puede utilizar de forma libre en cualquier sitio.

WhatWeb and Wappalyzer: Practical examples

Vamos a ver ahora estas dos herramientas que hemos comentado desde un punto de vista práctico.

WhatWeb

Para empezar, si escribimos en la terminal de Kali `whatweb` vemos que por defecto está bien instalado.

```
WhatWeb - Next generation web scanner version 0.5.5.
Developed by Andrew Horton (urbanadventurer) and Brendan Coles (bcoles)
Homepage: https://www.morningstarsecurity.com/research/whatweb

Usage: whatweb [options] <URLs>

<TARGETs>          Enter URLs, hostnames, IP addresses, filenames or
                    IP ranges in CIDR, x.x.x-x, or x.x.x.x-x.x.x.x
                    format.
--input-file=FILE, -i  Read targets from a file.
--aggression, -a=LEVEL Set the aggression level. Default: 1.
1. Stealthy          Makes one HTTP request per target and also
                    follows redirects.
3. Aggressive        If a level 1 plugin is matched, additional
                    requests will be made.
--list-plugins, -l    List all plugins.
--info-plugins, -I=[SEARCH] List all plugins with detailed information.
                    Optionally search with a keyword.
--verbose, -v        Verbose output includes plugin descriptions.

Note: This is the short usage help. For the complete usage help use -h or --help.
```

Nos dice que podemos introducir directamente el target o los targets URL, hostname, direcciones IP, etc, para empezar a escanearlos.

También nos dice que el input puede estar en un fichero y otras cuantas opciones más, como por ejemplo el modo en el que lo va a analizar, que puede ser más agresivo o menos.

Vamos a ir ahora a nuestro navegador y vamos a escribir la dirección IP de la máquina metasploitable 3 10.0.1.9. Como ya veíamos en otras clases, esta máquina

trae diferentes servicios web. Hay uno que es de /chat, otro que es de /drupal, /payroll_app y phpmyadmin. Vamos a analizar cada uno de ellos con WhatWeb.

Vamos a empezar por chat y si escribimos whatweb y pegamos la dirección de chat vamos a ver que tras unos segundos nos va a estar sacando información.

```
whatweb http://10.0.1.9/chat/
```

```
(kali@kali)-[~]
$ whatweb http://10.0.1.9/chat/
http://10.0.1.9/chat/ [200 OK] Apache[2.4.7], Cookies[PHPSESSID], Country[RESERVED][22], HTTPServer[Ubuntu Linux][Apache/2.4.7 (Ubuntu)], IP[10.0.1.9], PHP[5.4.5], Title[Metasploitable3 Chatroom], UncommonHeaders[access-control-allow-origin,access-control-allow-credentials], X-Powered-By[PHP/5.4.5]
```

Este chat está utilizando un Apache 2.4.7. Por otro lado podemos ver que también se basa en php, la versión 5.4.5.

Vamos a hacer ahora lo mismo para ese drupal.

```
whatweb http://10.0.1.9/drupal/
```

Vemos que a diferencia del otro, también se está utilizando PHP 5.4.5 y un Apache 2.4.7, pero aquí nos dice que bueno, está escrito en JavaScript, que además se trata de un Drupal 7 y que utiliza jQuery.

```
(kali@kali)-[~]
$ whatweb http://10.0.1.9/drupal/
http://10.0.1.9/drupal/ [200 OK] Apache[2.4.7], Country[RESERVED][22], Drupal, HTTPServer[Ubuntu Linux][Apache/2.4.7 (Ubuntu)], IP[10.0.1.9], JQuery, MetaGenerator[Drupal 7 (http://drupal.org)], PHP[5.4.5], PasswordField[pass], Script[text/javascript], Title[Metasploitable3], UncommonHeaders[x-generator], X-Powered-By[PHP/5.4.5]
```

Vamos ahora a probar con payroll_app.php a ver qué nos dice.

```
whatweb http://10.0.1.9/payroll_app.php/
```

```
(kali@kali)-[~]
$ whatweb http://10.0.1.9/payroll_app.php
http://10.0.1.9/payroll_app.php [200 OK] Apache[2.4.7], Country[RESERVED][22], HTTPServer[Ubuntu Linux][Apache/2.4.7 (Ubuntu)], IP[10.0.1.9], PHP[5.4.5], PasswordField[password], X-Powered-By[PHP/5.4.5]
```

Y lo mismo, PHP 5.4.5 y Apache 2.4.7.

Vemos que al ser páginas un poco más estáticas no nos está sacando mucha información de frameworks, herramientas de analíticas, etc.

Vamos por último a hacer la prueba con el phpMyAdmin.

```
whatweb http://10.0.1.9/phpmyadmin/
```

Pulsamos enter y vemos por aquí que ya nos dice un poco más de cosas.

```
(kali@kali)~$ whatweb http://10.0.1.9/phpmyadmin/
http://10.0.1.9/phpmyadmin/ [200 OK] Apache[2.4.7], Cookies[phpMyAdmin,pma_collation_connection,pma_lang,pma_mcrypt_iv], Country[RESERVED], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.7 (Ubuntu)], HttpOnly[phpMyAdmin,pma_collation_connection,pma_lang,pma_mcrypt_iv], IP[10.0.1.9], JQuery[1.6.2], PHP[5.4.5], PasswordField[pma_password], Script[text/javascript], Title[phpMyAdmin], X-Powered-By[PHP/5.4.5], phpMyAdmin
```

Nos dice que hay un Apache 2.4.7 corriendo por ahí, como ya sabíamos anteriormente. Nos dice que hay un PHP 5.4.5, pero ahora sí que nos saca librerías como jQuery 1.6.2. Nos dice por aquí que se trata de un phpMyAdmin, nos dice que utiliza como lenguaje HTML5 y en general nos saca un poquito más de información que los servicios anteriores.

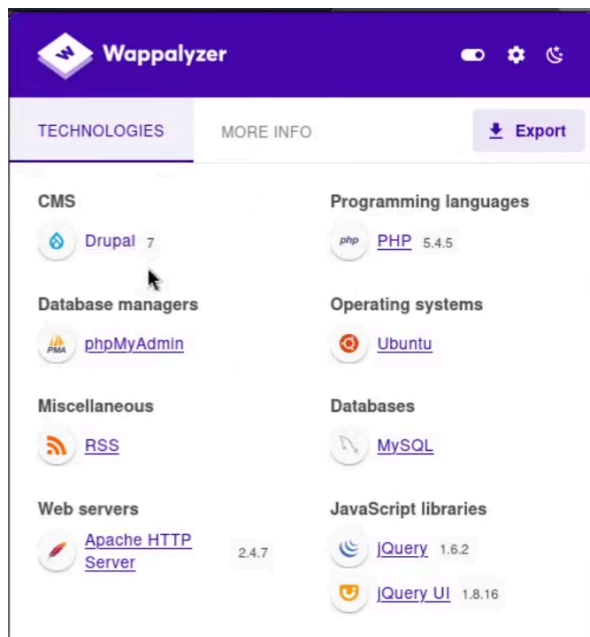
Wappalyzer

Vamos ahora al navegador y vamos a hacer este mismo análisis con Wappalyzer.

Para ello vamos aquí al icono de las extensiones, lo abrimos y escribimos wappalyzer. Pulsamos enter y nos va a abrir la tienda de addons de Firefox.

Tenemos por aquí Wappalyzer que vemos que ha sido instalado por 114.000 usuarios. Le damos añadir a Firefox y tras unos segundos aparecerá aquí una ventana. Le damos añadir y ya lo tenemos por aquí. Lo voy a pinear a la barra para acceder a él fácilmente. Vale, pues vamos a analizar con Wappalyzer estas páginas.

Aquí lo que ocurre es que como todas las páginas están utilizando el mismo dominio, que es 10.0.1.9, Wapalyzer entiende que todas las páginas son la misma, por lo que vamos a ver en una sola ventana en Wappalyzer las cuatro páginas condensadas.



Por eso podemos ver por aquí qué texto utiliza un Drupal 7, la versión de PHP es la 5.4.5. Nos dice que el gestor de base de datos es un phpMyAdmin y que la base de datos es MySQL. Esto WhatWeb no nos lo sacaba antes.

Nos dice también que el sistema operativo es Ubuntu, que tenemos un servidor web Apache en su versión 2.4.7 y además también nos dice algunas librerías de JavaScript que utilizan en estas páginas, que son jQuery y jQuery UI en sus versiones 1.6.2 y 1.8.16.

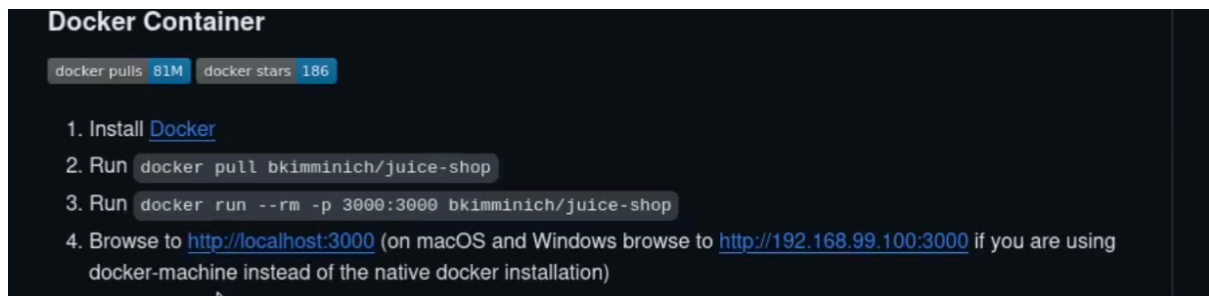
Using WhatWeb and Wappalyzer with juice-shop

Vamos a cambiar ahora de objetivo y vamos a ver juice-shop, esa tienda online de OWASP que os comentaba.

Entonces para ello vamos a abrir aquí nuestro navegador y vamos a buscar en GitHub el repositorio de juice-shop.

En este repositorio de GitHub podemos ver más abajo algunas instrucciones de cómo instalarlo. Podemos instalarlo desde el código fuente, como un contenedor docker, vagrant, en un Amazon EC2, etc.

Nosotros vamos a optar por instalarlo como un contenedor docker. Para ello copiamos este comando que vemos por aquí y nos vamos a una terminal.



Vamos a comprobar que tenemos docker instalado con `docker --version` y ejecutamos el comando que hemos copiado, que lo que hará será descargar y arrancar la imagen de juice-shop exponiendo el puerto 3000.

```
docker run --rm -p 3000:3000 bkimminich/juice-shop
```

Pulsamos enter y si todo va bien comenzará la descarga de esta imagen.

```
(kali@kali)-[~]
$ docker --version
Docker version 20.10.25-dfsg1, build b82b9f3

(kali@kali)-[~]
$ docker run --rm -p 3000:3000 bkimminich/juice-shop
info: All dependencies in ./package.json are satisfied (OK)
info: Detected Node.js version v20.10.0 (OK)
info: Detected OS linux (OK)
info: Detected CPU x64 (OK)
info: Configuration default validated (OK)
info: Entity models 19 of 19 are initialized (OK)
info: Required file server.js is present (OK)
info: Required file polyfills.js is present (OK)
info: Required file runtime.js is present (OK)
info: Required file index.html is present (OK)
info: Required file styles.css is present (OK)
info: Required file vendor.js is present (OK)
info: Required file main.js is present (OK)
info: Port 3000 is available (OK)
info: Chatbot training data botDefaultTrainingData.json validated (OK)
info: Domain https://www.alchemy.com/ is reachable (OK)
info: Server listening on port 3000
```

Vemos por aquí que el servidor y el puerto ya están disponibles en el puerto 3000.

Vamos a nuestro navegador de nuevo y escribimos `localhost:3000`.

Por aquí tenemos owasp juice-shop. Recargamos la web.

Primero vamos a analizarlo con WhatWeb a ver qué saca.

Para ello nos abrimos otra terminal y escribimos whatweb y pegamos la dirección del navegador localhost:3000.

```
whatweb http://localhost:3000/#/
```

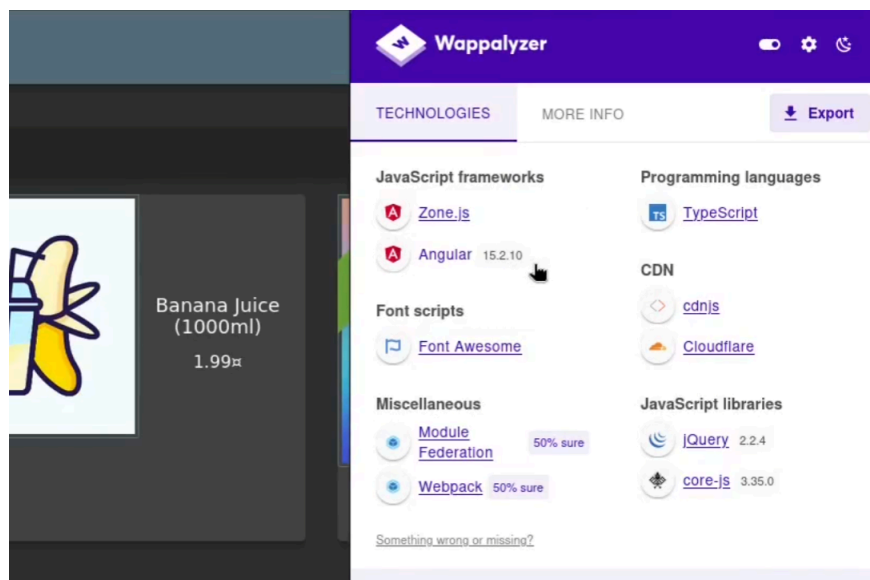
Tras unos segundos ya vemos por aquí que ha sacado algunas cositas.

```
(kali@kali)-[~]
└─$ whatweb http://localhost:3000/#/
http://localhost:3000/#/ [200 OK] HTML5, IP[::1], JQuery[2.2.4], Script[module], Title[OWASP Juice Shop], UncommonHeaders[access-control-allow-origin,x-content-type-options,feature-policy,x-recruiting], X-Frame-Options[SAMEORIGIN]
```

Nos dice que solo ha sacado que esta página utiliza HTML5 y la versión de jQuery en su versión 2.2.4.

Vamos a Wappalyzer y al final es una extensión que está un poco más actualizada.

Para ver qué cositas ha sacado, vamos a pulsar en el icono de wappalyzer del navegador y vemos que por aquí hay alguna cosa más.

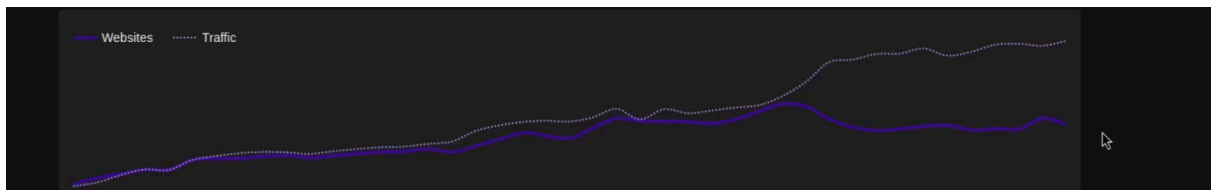


Nos dice por ejemplo que está utilizando Angular en su versión 15.2.10. Está utilizando también una librería de Angular que es Zone.js, que está utilizando font awesome, una librería de iconos. Por aquí alguna cosita más pero que nos dice que está al 50% seguro, es decir, que puede que no lo esté utilizando.

También nos dice que las librerías de JavaScript que está utilizando jQuery 2.2.4 y core-js en la versión 335.

Vemos que en eso sí que lleva razón WhatWeb, han sacado la misma versión de jQuery.

Además Wappalyzer nos permite que si clickamos sobre una tecnología en concreto nos va a abrir una página y aquí vamos a ver que es Angular, por ejemplo. Vamos a ver qué sitio web lo están utilizando y vamos a ver por aquí también el tráfico que tienen los sitios web utilizando esta tecnología. Por ejemplo en Angular vemos que hay muchos sitios web que utilizan esta tecnología, pero el tráfico de estos sitios web aún es mayor.



También nos dice dónde se utiliza más esta tecnología, por ejemplo en Estados Unidos, aunque esto también puede ser por el tamaño del país en cuestión, que tiene mucho más sitios web hosteados con esta tecnología que otro país más pequeño.

En general un poco comparaciones entre las diferentes tecnologías, por ejemplo en el caso de Angular, comparaciones con React, con Vue, etc.

whatruns: Alternative to Wappalyzer

Por último, otra alternativa que podéis utilizar es wappalyzer, se trata de otra extensión que se llama whatruns.

Como podéis ver esta extensión también es utilizada por bastante gente y es similar al funcionamiento de wappalyzer.